

Normativa reguladora de la protección de datos personales: principios, derechos de las personas y ejercicios de los derechos.

Cuerpo: Cuerpo Administrativo de la Administración de la Seguridad Social

Subgrupo y acceso: C1 · sistema general de acceso libre

Actualización: 30 de julio de 2026

Programa: Anexo I de la Resolución de 22 de diciembre de 2025

AVISO DE PROPIEDAD INTELECTUAL

© 2026 ACADEMIA LORMAN. Todos los derechos reservados.

Material protegido por el Real Decreto Legislativo 1/1996, de 12 de abril, por el que se aprueba el texto refundido de la Ley de Propiedad Intelectual.

Queda prohibida su reproducción, distribución, comunicación pública, modificación, venta, cesión, publicación o difusión, total o parcial, sin autorización previa y por escrito de su titular.

No está permitida su publicación en páginas web, plataformas digitales, redes sociales, grupos de mensajería, aplicaciones, repositorios o servicios de intercambio de archivos.

Contenido actualizado y revisado a fecha de 30 de julio de 2026.

La protección de datos garantiza que cada persona conserve poder de disposición y control sobre la información que la identifica. No se limita a guardar secretos: ordena por qué, para qué, durante cuánto tiempo y con qué garantías pueden tratarse datos personales.

Tema actualizado a 30 de julio de 2026. El marco central es el Reglamento (UE) 2016/679, de 27 de abril (RGPD), aplicable desde el 25 de mayo de 2018, y la Ley Orgánica 3/2018, de 5 de diciembre (LOPDGDD), que adapta y completa el Derecho español y reconoce derechos digitales. Para tratamientos de autoridades competentes con fines penales rige la Ley Orgánica 7/2021.

1. Fundamento y sistema normativo

1.1. Constitución y derecho autónomo

El artículo 18.4 de la Constitución ordena que la ley limite el uso de la informática para garantizar honor e intimidad personal y familiar y el pleno ejercicio de los derechos. El Tribunal Constitucional ha configurado un derecho fundamental autónomo: faculta a conocer qué datos se poseen, para qué se usan y quién los utiliza, y a oponerse a usos ilícitos.

Debe distinguirse:

- Intimidad: protege un ámbito reservado frente a intromisiones.
- Protección de datos: concede facultades de control sobre cualquier dato personal, aunque no sea íntimo.
- Secreto de las comunicaciones: protege el proceso comunicativo en los términos del artículo 18.3 CE.

El artículo 8 de la Carta de Derechos Fundamentales de la Unión Europea reconoce el derecho a protección de datos, el tratamiento leal para fines determinados sobre consentimiento u otro fundamento legítimo, el acceso y rectificación y el control por autoridad independiente.

1.2. RGPD y LOPDGDD

El RGPD es una norma de la Unión directamente aplicable. Pretende un nivel equivalente de protección y la libre circulación de datos dentro de la Unión. La LOPDGDD:

- Adapta el ordenamiento español.
- Concreta remisiones que el RGPD deja a los Estados.
- Regula la Agencia Española de Protección de Datos y autoridades autonómicas.
- Establece régimen sancionador y disposiciones sobre tratamientos concretos.
- Garantiza derechos digitales.

La ley orgánica no sustituye ni reproduce por completo el Reglamento. En examen debe aplicarse primero el RGPD y completar con la norma española.

1.3. Otros regímenes

La Ley Orgánica 7/2021 regula tratamientos efectuados por autoridades competentes para prevención, detección, investigación y enjuiciamiento de infracciones penales o ejecución de sanciones penales, incluidas protección y prevención frente a amenazas a la seguridad pública. Es un régimen específico, no una base ordinaria del RGPD.

También existen normas sectoriales sobre comunicaciones electrónicas, sanidad, prevención del blanqueo, archivos, estadística, Seguridad Social, empleo público y transparencia. La publicación o cesión por una Administración necesita habilitación jurídica y debe respetar minimización y finalidad.

2. Ámbito del RGPD

2.1. Ámbito material

El RGPD se aplica al tratamiento total o parcialmente automatizado y al tratamiento no automatizado de datos contenidos o destinados a incluirse en un fichero.

No se aplica, entre otros supuestos:

- A actividades no comprendidas en el Derecho de la Unión, como determinadas actividades de seguridad nacional.
- A tratamientos de una persona física en una actividad exclusivamente personal o doméstica, sin conexión profesional o comercial.
- A los tratamientos penales de autoridades competentes regidos por la normativa específica.
- A datos de personas jurídicas como tales.

Protege a personas físicas vivas. La LOPDGDD permite que personas vinculadas al fallecido, herederos o personas designadas soliciten acceso, rectificación o supresión de sus datos, salvo prohibición expresa del fallecido o de la ley. Esa regla nacional no convierte al fallecido en interesado a efectos del RGPD.

2.2. Ámbito territorial

Se aplica al tratamiento realizado en el contexto de las actividades de un establecimiento del responsable o encargado en la Unión, con independencia de dónde tenga lugar materialmente el tratamiento.

También alcanza a responsables o encargados sin establecimiento en la Unión cuando tratan datos de personas que se encuentran en ella relacionados con:

- Oferta de bienes o servicios, exista o no pago.
- Control de su comportamiento en la medida en que tenga lugar en la Unión.

Se aplica asimismo cuando el responsable no está establecido en la Unión, pero el Derecho de un Estado miembro resulta aplicable por Derecho internacional público.

3. Sujetos y conceptos

3.1. Dato personal y tratamiento

Dato personal es toda información sobre una persona física identificada o identificable. Una persona es identificable directa o indirectamente mediante nombre, número, localización, identificador en línea o elementos propios de su identidad física, fisiológica, genética, psíquica, económica, cultural o social.

No solo son datos el DNI o domicilio. También pueden serlo una matrícula, dirección IP, imagen, voz, historial laboral o combinación de elementos que permita singularizar a alguien con medios razonablemente utilizables.

Tratamiento es cualquier operación sobre datos, automatizada o no: recogida, registro, organización, estructuración, conservación, adaptación, consulta, utilización, comunicación, difusión, cotejo, limitación, supresión o destrucción.

Los datos verdaderamente anónimos quedan fuera del RGPD. Los seudonimizados siguen siendo personales si pueden atribuirse a una persona usando información adicional, que debe mantenerse separada y protegida.

3.2. Responsable, encargado y otros sujetos

El responsable determina fines y medios del tratamiento. El encargado trata datos por cuenta del responsable. La diferencia depende de la función real, no del nombre del contrato.

El encargado debe estar vinculado por contrato u otro acto jurídico que defina objeto, duración, naturaleza, finalidad, tipos de datos, categorías de interesados y obligaciones. Solo trata conforme a instrucciones documentadas; garantiza confidencialidad, seguridad, asistencia, destino de datos al terminar y auditoría. No puede recurrir a otro encargado sin autorización.

Si dos o más sujetos determinan conjuntamente fines y medios son corresponsables y distribuyen transparentemente sus responsabilidades, sin privar al interesado de ejercer derechos frente a cualquiera.

Otros conceptos:

- Interesado: persona física a quien se refieren los datos.
- Destinatario: quien recibe una comunicación, sea o no tercero, con la excepción reglamentaria de ciertas autoridades investigadoras.
- Tercero: sujeto distinto del interesado, responsable, encargado y personas autorizadas bajo autoridad directa.
- Consentimiento: manifestación libre, específica, informada e inequívoca mediante declaración o clara acción afirmativa.
- Perfilado: tratamiento automatizado para evaluar aspectos personales, como rendimiento, situación económica, salud, preferencias, fiabilidad, comportamiento o movimientos.
- Violación de seguridad: destrucción, pérdida, alteración o comunicación o acceso no autorizados, accidentales o ilícitos.

4. Principios del tratamiento

El artículo 5 RGPD contiene siete principios. El responsable debe cumplirlos y poder demostrarlo: es la responsabilidad proactiva.

4.1. Licitud, lealtad y transparencia

Los datos se tratan de manera lícita, leal y transparente. Licitud exige una base del artículo 6 y, si procede, una excepción del artículo 9. Lealtad prohíbe usos engañosos o perjudiciales inesperados. Transparencia exige informar de modo comprensible y facilitar el control.

Una información formalmente extensa pero ininteligible no satisface la transparencia. Tampoco puede ocultarse una finalidad real bajo una descripción vaga.

4.2. Limitación de la finalidad

Los datos se recogen con fines determinados, explícitos y legítimos y no se tratan ulteriormente de forma incompatible. Archivo en interés público, investigación científica o histórica y estadística no se consideran incompatibles si se aplican las garantías del RGPD.

Para valorar compatibilidad se atiende a relación entre fines, contexto y expectativas, naturaleza de datos, consecuencias y garantías como cifrado o seudonimización. Si el nuevo tratamiento es incompatible, necesita una base propia y nueva información.

4.3. Minimización

Los datos deben ser adecuados, pertinentes y limitados a lo necesario. «Puede resultar útil» no basta. Debe poder explicarse por qué cada categoría es necesaria para la finalidad.

La protección de datos desde el diseño y por defecto aplica esta idea: por defecto solo se tratarán los datos necesarios en cantidad, extensión, conservación y accesibilidad.

4.4. Exactitud

Los datos deben ser exactos y, si fuera necesario, actualizados. Se adoptarán medidas razonables para suprimir o rectificar sin dilación los inexactos.

La LOPDGDD considera que el responsable no es imputable por inexactitud cuando los datos se obtuvieron directamente del afectado, de mediador habilitado, de otro responsable en ejercicio de portabilidad o de registro público, siempre que haya adoptado las medidas correspondientes. Esto no elimina el derecho a rectificación.

4.5. Limitación del plazo de conservación

Los datos se conservan de forma identificable no más tiempo del necesario. Pueden mantenerse más tiempo para archivo en interés público, investigación o estadística con medidas técnicas y organizativas.

Finalizada la finalidad, no siempre procede destrucción inmediata: puede ser obligatorio el bloqueo para atender responsabilidades durante sus plazos de prescripción. Bloqueo no equivale a uso ordinario.

4.6. Integridad y confidencialidad

Debe garantizarse seguridad adecuada frente a tratamiento no autorizado o ilícito y pérdida, destrucción o daño accidental mediante medidas técnicas u organizativas. La LOPDGDD impone deber de confidencialidad a responsables, encargados y quienes intervengan, compatible con deberes de secreto profesional y subsistente al terminar la relación.

4.7. Responsabilidad proactiva

No basta cumplir de modo reactivo. El responsable debe analizar riesgos, seleccionar medidas, documentarlas y demostrar cumplimiento. De aquí derivan registro de actividades, evaluación de impacto, privacidad desde el diseño, gestión de brechas, contratos de encargo, políticas y formación.

Principio	Pregunta de control
Licitud, lealtad y transparencia	¿Existe base, trato honesto e información clara?
Finalidad	¿Está el uso determinado y es compatible?
Minimización	¿Cada dato es necesario?
Exactitud	¿Se mantiene correcto y actualizado?
Conservación	¿Hay plazo y política de borrado o bloqueo?
Integridad y confidencialidad	¿Se evita acceso, alteración o pérdida?
Responsabilidad proactiva	¿Puede demostrarse lo anterior?

5. Licitud y categorías especialmente protegidas

5.1. Bases jurídicas del artículo 6

Todo tratamiento debe apoyarse en al menos una base:

1. Consentimiento del interesado para una o varias finalidades.
2. Contrato: tratamiento necesario para ejecutarlo o para medidas precontractuales solicitadas.
3. Obligación legal del responsable.

4. Intereses vitales del interesado u otra persona.
5. Misión de interés público o ejercicio de poderes públicos conferidos al responsable.
6. Interés legítimo del responsable o tercero, salvo que prevalezcan intereses, derechos y libertades del interesado, especialmente si es menor.

El interés legítimo no se aplica a autoridades públicas cuando desempeñan sus funciones. En el sector público son habituales obligación legal e interés público/poder público, cuya base debe establecerse en Derecho de la Unión o norma con rango suficiente conforme a la LOPDGDD.

Las bases no son intercambiables a conveniencia. La Administración no debe pedir consentimiento si el tratamiento es obligatorio y se apoya en una competencia legal, porque ese consentimiento puede no ser libre y su retirada no paralizaría la obligación.

5.2. Consentimiento

El responsable debe probar que se prestó. Debe ser:

- Libre, sin desequilibrio, perjuicio por negarse ni condicionamiento de un contrato a datos innecesarios.
- Específico para finalidades diferenciadas.
- Informado.
- Inequívoco mediante declaración o acción afirmativa clara.

No son válidos silencio, inacción ni casillas premarcadas. Puede retirarse en cualquier momento con la misma facilidad con que se dio; la retirada no afecta a la licitud anterior. Si se recogen varias finalidades, debe permitirse decidir separadamente cuando corresponda.

En España, el tratamiento basado en consentimiento del menor puede fundarse en el suyo cuando sea mayor de catorce años, salvo que la ley exija asistencia de quienes ejerzan patria potestad o tutela. Para menores de catorce se necesita consentimiento de sus representantes. Esto no rebaja otras edades previstas para negocios o derechos distintos.

5.3. Categorías especiales

El artículo 9 prohíbe, como regla, tratar datos que revelen:

- Origen étnico o racial.
- Opiniones políticas.
- Convicciones religiosas o filosóficas.
- Afiliación sindical.
- Datos genéticos.
- Datos biométricos dirigidos a identificar de manera unívoca.
- Datos relativos a salud.
- Vida sexual u orientación sexual.

La prohibición se levanta solo si concurre una excepción: consentimiento explícito; obligaciones y derechos laborales y de protección social; intereses vitales si no se puede consentir; actividades legítimas de determinadas entidades sin ánimo de lucro respecto de sus miembros; datos manifiestamente públicos por el interesado; reclamaciones y función judicial; interés público esencial previsto por ley; medicina y asistencia sanitaria o social; salud pública; archivo, investigación o estadística con garantías.

La LOPDGDD establece que el solo consentimiento no basta cuando la finalidad principal sea identificar ideología, afiliación sindical, religión, orientación sexual, creencias u origen racial o

étnico. El tratamiento necesitará otra habilitación adecuada. Esta cautela no impide que el consentimiento explícito sirva en otros supuestos permitidos por el RGPD.

Los datos sobre condenas e infracciones penales no forman parte técnicamente de la lista del artículo 9. Se someten al artículo 10: tratamiento bajo control de autoridad pública o autorizado por Derecho de la Unión o ley con garantías. El registro completo de condenas solo puede llevarse bajo control oficial.

6. Información y transparencia

6.1. Requisitos de forma

La información y las comunicaciones sobre derechos deben ser concisas, transparentes, inteligibles, fácilmente accesibles y redactadas en lenguaje claro, especialmente si se dirigen a menores. Se proporcionan por escrito o medios electrónicos y, cuando se solicite, oralmente si se acredita identidad.

Puede utilizarse información por capas: una primera capa ofrece identidad del responsable, finalidad, posibilidad de ejercer derechos y, si existe, perfilado; una dirección permite acceder de inmediato al resto. La técnica no autoriza a esconder elementos esenciales.

6.2. Datos obtenidos del interesado

En el momento de recogerlos se informa, según proceda, sobre:

- Identidad y contacto del responsable y representante.
- Datos de contacto del delegado de protección de datos.
- Fines y base jurídica; interés legítimo si se invoca.
- Destinatarios.
- Transferencias internacionales y garantías.
- Plazo de conservación o criterios.
- Derechos de acceso, rectificación, supresión, limitación, oposición y portabilidad.
- Retirada del consentimiento y reclamación ante autoridad.
- Carácter obligatorio o contractual del dato y consecuencias de no facilitarlo.
- Decisiones automatizadas, lógica significativa y consecuencias previstas.

No es necesario repetir información que el interesado ya conoce.

6.3. Datos no obtenidos del interesado

Además de lo anterior, deben indicarse categorías de datos y fuente, incluida si es de acceso público. La información se facilita:

- Dentro de un plazo razonable y como máximo un mes desde la obtención.
- A más tardar en la primera comunicación con el interesado.
- A más tardar cuando se comuniquen por primera vez a otro destinatario.

No se exige si el interesado ya dispone de ella; resulta imposible o supone esfuerzo desproporcionado con las garantías debidas; la obtención o comunicación está expresamente establecida por ley; o existe deber legal de secreto profesional.

7. Reglas comunes para ejercer derechos

7.1. Facilitación e identidad

El responsable debe facilitar el ejercicio y no puede negarse salvo que demuestre que no puede identificar al solicitante. Puede pedir información adicional necesaria si tiene dudas razonables sobre identidad, sin exigir datos excesivos.

Los derechos son gratuitos. Ante solicitudes manifiestamente infundadas o excesivas, especialmente repetitivas, puede cobrar un canon razonable por costes administrativos o negarse a actuar. El responsable prueba el carácter infundado o excesivo.

Pueden ejercerse directamente o mediante representante. El encargado atiende solo en la medida prevista en el contrato y traslada la solicitud al responsable. El delegado asesora, pero quien responde jurídicamente es el responsable.

7.2. Plazo y respuesta

El responsable informa sobre las actuaciones sin dilación indebida y, como máximo, en un mes desde la recepción. Puede ampliar el plazo otros dos meses por complejidad o número de solicitudes, pero debe comunicar la ampliación y sus motivos dentro del primer mes.

Si no actúa, informa dentro de un mes de los motivos y de la posibilidad de reclamar ante autoridad y acudir a los tribunales. Si la solicitud se presenta electrónicamente, la respuesta será electrónica cuando sea posible, salvo petición distinta.

Actuación	Plazo
Responder al derecho	1 mes
Ampliación máxima	2 meses adicionales
Informar de la ampliación	Dentro del primer mes
Informar de que no se actúa	Dentro de 1 mes

No debe confundirse este plazo con las 72 horas para notificar una violación de seguridad a la autoridad.

7.3. Reclamación y tutela

La persona puede presentar reclamación ante una autoridad de control, especialmente en el Estado de residencia habitual, trabajo o lugar de la supuesta infracción. Dispone también de recurso judicial efectivo contra decisiones o inactividad de la autoridad y contra responsable o encargado.

Quien sufra daños materiales o inmateriales por infracción tiene derecho a indemnización. Responsable y encargado responden según su participación y pueden quedar exentos si prueban que no son responsables del hecho dañoso.

8. Derechos concretos

8.1. Acceso

Permite obtener confirmación de si se tratan datos y, en tal caso, acceso a ellos y a:

- Fines y categorías.
- Destinatarios, especialmente internacionales.
- Plazo o criterios de conservación.
- Derechos de rectificación, supresión, limitación y oposición.

- Reclamación ante autoridad.
- Origen cuando no se obtuvieron del interesado.
- Decisiones automatizadas y lógica y consecuencias significativas.
- Garantías de transferencias internacionales.

El responsable entrega una copia. Las copias adicionales pueden generar canon basado en costes. La entrega no debe afectar negativamente a derechos y libertades de terceros.

La LOPDGDD considera repetitivo el acceso solicitado más de una vez en seis meses, salvo causa legítima. Si se ofrece un sistema remoto, directo y seguro de acceso permanente puede darse por atendido, sin perjuicio de que el interesado solicite información adicional.

8.2. Rectificación

El interesado puede obtener sin dilación la rectificación de datos inexactos y completar los incompletos, incluso mediante declaración adicional. En España debe indicar a qué datos se refiere y qué corrección solicita, acompañando justificación cuando sea necesaria.

Rectificar no permite alterar datos objetivos correctos por mera discrepancia con una valoración. Sí obliga a corregir hechos inexactos y a incorporar aclaraciones pertinentes.

8.3. Supresión

Procede sin dilación cuando:

- Los datos ya no son necesarios.
- Se retira el consentimiento y no existe otra base.
- Se formula oposición y no prevalecen motivos legítimos o se trata de mercadotecnia directa.
- El tratamiento es ilícito.
- Deben suprimirse por obligación legal.
- Se obtuvieron en relación con servicios de la sociedad de la información ofrecidos a menores.

No es absoluto. Puede conservarse lo necesario para libertad de expresión e información; obligación legal o misión pública; salud pública; archivo, investigación o estadística cuando la supresión impida gravemente fines; y formulación, ejercicio o defensa de reclamaciones.

Si el responsable hizo públicos los datos y debe suprimirlos, adoptará medidas razonables para informar a otros responsables que traten enlaces, copias o réplicas. Esta es una manifestación del denominado derecho al olvido.

8.4. Limitación

La limitación procede cuando:

- Se impugna exactitud, durante su verificación.
- El tratamiento es ilícito y se prefiere limitar a suprimir.
- El responsable ya no necesita los datos, pero el interesado sí para reclamaciones.
- Se formula oposición, mientras se comprueba qué intereses prevalecen.

Durante la limitación, salvo conservación, solo pueden tratarse con consentimiento, para reclamaciones, protección de derechos de otra persona o interés público importante. Antes de levantarla se informa al interesado.

8.5. Comunicación a destinatarios

El responsable comunica cada rectificación, supresión o limitación a los destinatarios, salvo imposibilidad o esfuerzo desproporcionado. Si el interesado lo pide, le informa sobre esos destinatarios. Es una obligación instrumental, no un derecho autónomo a borrar datos en sistemas ajenos sin límites.

8.6. Portabilidad

Permite recibir los datos que el interesado haya facilitado en formato estructurado, de uso común y lectura mecánica, y transmitirlos a otro responsable cuando:

- La base sea consentimiento o contrato.
- El tratamiento sea automatizado.

Puede pedirse transmisión directa si es técnicamente posible. No se aplica al tratamiento necesario para misión pública o ejercicio de poderes públicos y no puede perjudicar derechos de terceros. Solo comprende datos «facilitados», incluidos los observados por el uso, no necesariamente inferencias creadas por el responsable.

8.7. Oposición

Ante tratamientos basados en interés público, poder público o interés legítimo, el interesado puede oponerse por motivos relacionados con su situación particular. El responsable cesa salvo que acredite motivos legítimos imperiosos que prevalezcan o la necesidad para reclamaciones.

Ante mercadotecnia directa, incluida elaboración de perfiles relacionada, la oposición es absoluta: recibida, los datos dejan de tratarse para ese fin. Los responsables que hagan comunicaciones comerciales deben consultar los sistemas de exclusión publicitaria que correspondan.

8.8. Decisiones individuales automatizadas

Existe derecho a no ser objeto de una decisión basada únicamente en tratamiento automatizado, incluido perfilado, que produzca efectos jurídicos o afecte significativamente de modo similar.

Cabe excepción si la decisión:

- Es necesaria para celebrar o ejecutar un contrato.
- Está autorizada por ley con garantías.
- Se basa en consentimiento explícito.

En contrato o consentimiento deben garantizarse intervención humana, posibilidad de expresar el punto de vista e impugnar la decisión. El uso de categorías especiales exige consentimiento explícito o interés público esencial y medidas adecuadas.

9. Obligaciones del responsable y del encargado

9.1. Riesgo y medidas de cumplimiento

El responsable aplicará medidas técnicas y organizativas apropiadas considerando naturaleza, ámbito, contexto, fines y riesgos de distinta probabilidad y gravedad. Las revisará y actualizará. Pueden incluir políticas, asignación de funciones, formación, control de accesos, copias, cifrado, seudonimización, evaluación y auditoría.

El RGPD no establece una lista idéntica de medidas para toda organización. Exige adecuación al riesgo. El hecho de no haber sufrido una brecha no demuestra cumplimiento si no existe análisis previo.

9.2. Protección desde el diseño y por defecto

Desde que se concibe el tratamiento se integran garantías: minimización, seudonimización, plazos, control de acceso y mecanismos para derechos. Por defecto, solo se tratan datos necesarios para cada fin en cantidad, extensión, conservación y accesibilidad.

«Desde el diseño» actúa antes y durante el tratamiento; «por defecto» determina la configuración ordinaria más protectora. Ninguna consiste solo en añadir una cláusula informativa al final.

9.3. Registro de actividades

Responsables y encargados llevan un registro escrito, incluido electrónico, con información exigida: contactos, fines, categorías de interesados y datos, destinatarios, transferencias, plazos previstos de supresión y descripción general de seguridad. El del encargado recoge responsables por cuya cuenta actúa y categorías de tratamientos.

La excepción para organizaciones con menos de 250 personas no opera cuando el tratamiento puede entrañar riesgo, no es ocasional o incluye categorías especiales o datos penales. En la práctica, muchas actividades quedan registradas.

9.4. Seguridad

Responsable y encargado aplican seguridad adecuada al riesgo, que puede incluir:

- Seudonimización y cifrado.
- Confidencialidad, integridad, disponibilidad y resiliencia permanentes.
- Restauración rápida de disponibilidad y acceso tras incidente.
- Verificación y evaluación periódica de eficacia.

Se consideran estado de la técnica, costes, naturaleza y contexto, y probabilidad y gravedad del riesgo. Las personas autorizadas solo tratan datos siguiendo instrucciones, salvo obligación legal.

9.5. Violaciones de seguridad

Una brecha puede afectar confidencialidad, integridad o disponibilidad. El encargado informa al responsable sin dilación indebida cuando tenga conocimiento.

El responsable notifica a la autoridad de control sin dilación indebida y, de ser posible, dentro de 72 horas desde que tenga constancia, salvo que sea improbable que entrañe riesgo para derechos y libertades. Si tarda más, justifica la demora. La notificación describe naturaleza, categorías y número aproximado, contacto del delegado, consecuencias y medidas adoptadas o propuestas. Puede facilitarse por fases.

Cuando sea probable un alto riesgo, comunica la brecha al interesado sin dilación, en lenguaje claro. No es necesaria si:

- Existían medidas que hacen ininteligibles los datos, como cifrado robusto.
- Medidas posteriores eliminan la probabilidad de alto riesgo.
- Exigiría esfuerzo desproporcionado, en cuyo caso se realiza comunicación pública equivalente.

Toda brecha se documenta, se notifique o no. Por tanto:

Supuesto	Actuación
Encargado conoce brecha	Informa al responsable sin dilación
Riesgo para derechos	Responsable notifica autoridad, en lo posible ≤72 h

Supuesto	Actuación
Alto riesgo	Además comunica a interesados sin dilación
Riesgo improbable	No notifica, pero documenta

9.6. Evaluación de impacto y consulta previa

Antes de un tratamiento que probablemente entrañe alto riesgo, el responsable realiza una evaluación de impacto. Se exige especialmente ante:

- Evaluación sistemática y exhaustiva basada en tratamiento automatizado con decisiones significativas.
- Tratamiento a gran escala de categorías especiales o datos penales.
- Observación sistemática a gran escala de una zona de acceso público.

La evaluación describe tratamiento y fines, necesidad y proporcionalidad, riesgos y medidas. Si queda alto riesgo que no puede mitigarse, se consulta a la autoridad antes de tratar. No debe confundirse evaluación de impacto —la hace el responsable— con autorización general de la Agencia, que el RGPD no exige para todo fichero.

9.7. Delegado de protección de datos

Debe designarse delegado cuando:

- El tratamiento lo realiza una autoridad u organismo público, salvo tribunales en su función judicial.
- Las actividades principales requieren observación habitual y sistemática a gran escala.
- Las actividades principales consisten en tratamiento a gran escala de categorías especiales o datos penales.
- Lo exige un supuesto adicional de la LOPDGDD.

La norma española añade entidades como colegios profesionales, centros docentes, determinadas entidades financieras y aseguradoras, prestadores sanitarios obligados a historia clínica, operadores de comunicaciones, prestadores de servicios de la sociedad de la información con perfiles a gran escala, empresas de seguridad privada y federaciones deportivas con datos de menores, entre otras.

El delegado puede ser interno o externo, persona física o jurídica con conocimientos especializados. Informa y asesora, supervisa, coopera con la autoridad y actúa como contacto. Debe participar a tiempo, disponer de recursos, acceder al máximo nivel, no recibir instrucciones ni ser sancionado por ejercer sus funciones, guardar secreto y evitar conflictos. No sustituye al responsable ni responde personalmente de todo incumplimiento.

10. Transferencias internacionales

Una transferencia fuera del Espacio Económico Europeo solo puede realizarse manteniendo el nivel de protección:

1. Decisión de adecuación de la Comisión.
2. En su defecto, garantías adecuadas: cláusulas tipo, normas corporativas vinculantes, instrumentos públicos, códigos o certificaciones con compromisos.
3. Excepcionalmente, alguna excepción del artículo 49, como consentimiento explícito informado, contrato, interés público importante, reclamaciones o intereses vitales.

La excepción no debe convertirse en cauce habitual. Antes de usar garantías contractuales se valora si el Derecho y práctica del tercer país permiten protección efectiva y, si hace falta, medidas suplementarias.

11. Tratamientos específicos de la LOPDGDD

11.1. Datos de contacto y función empresarial

Salvo prueba en contrario, existe interés legítimo para tratar datos de contacto profesionales y, en su caso, función o puesto, si se limita a localización profesional y la finalidad es relacionarse con la persona jurídica para la que trabaja. Regla análoga se aplica a empresarios individuales y profesionales liberales, sin mezclar su esfera privada.

11.2. Sistemas de exclusión publicitaria

Pueden crearse sistemas para evitar comunicaciones de mercadotecnia directa. Quien pretenda realizar estas comunicaciones debe consultar los sistemas que puedan afectar a su campaña y excluir a quienes hayan manifestado oposición. No será necesario consultar si el interesado prestó consentimiento específico a esa entidad.

La inclusión en una lista no borra toda información de la persona: permite conservar lo mínimo necesario para hacer efectiva su oposición.

11.3. Videovigilancia

Personas físicas o jurídicas pueden tratar imágenes para preservar seguridad de personas, bienes e instalaciones. Solo se capta vía pública en la medida imprescindible o con habilitación específica. Se informa mediante dispositivo visible que identifique el tratamiento y cómo obtener información adicional.

Las imágenes se suprimen en un máximo de un mes, salvo conservación para acreditar actos contra personas, bienes o instalaciones. En ese caso se ponen a disposición de la autoridad competente como máximo en 72 horas desde que se conoce la grabación. No se aplica el bloqueo ordinario a estas imágenes en los mismos términos.

11.4. Sistemas internos de información

Es lícito crear sistemas para comunicar actos contrarios a la normativa y tramitar las comunicaciones. Se limita el acceso, se garantiza confidencialidad y se aplican los plazos de conservación y la normativa específica de protección del informante. Los datos que no sean necesarios o se refieran a conductas fuera del sistema deben suprimirse.

11.5. Bloqueo

Al rectificar o suprimir, el responsable bloquea los datos: los identifica y reserva, impidiendo su tratamiento y visualización salvo puesta a disposición de jueces, tribunales, Ministerio Fiscal o Administraciones competentes —en especial autoridades de protección de datos— para exigir responsabilidades.

El bloqueo dura el plazo de prescripción de responsabilidades; después, se destruyen. Si técnicamente no puede bloquearse o exige esfuerzo desproporcionado, la autoridad puede fijar excepciones. No debe confundirse:

- Limitación: derecho del interesado del artículo 18 RGPD, con causas y usos permitidos.
- Bloqueo: obligación nacional tras rectificación o supresión para posibles responsabilidades.

11.6. Derechos digitales

El título X reconoce, entre otros, neutralidad y acceso universal a internet, seguridad y educación digital, protección de menores, rectificación y actualización en medios digitales, privacidad en dispositivos laborales, desconexión digital, intimidad frente a videovigilancia y geolocalización, negociación colectiva y testamento digital.

Estos derechos no eliminan el RGPD. Por ejemplo, el control empresarial mediante dispositivos requiere información, proporcionalidad y respeto a intimidad; la desconexión exige política interna y formación; y la difusión de datos de menores debe proteger su interés superior.

12. Autoridades de control

12.1. Independencia, funciones y poderes

Cada Estado dispone de una o más autoridades públicas independientes. Actúan con total independencia: sus miembros no reciben instrucciones y deben estar libres de influencias externas.

Sus funciones incluyen supervisar, promover conocimiento, asesorar, atender reclamaciones, cooperar, investigar, mantener listas de evaluaciones, aprobar instrumentos cuando proceda y controlar aplicación. Tienen poderes:

- Investigación: ordenar información, auditorías, revisar certificaciones, acceder a datos y locales.
- Correctivos: advertir, apercibir, ordenar atender derechos, limitar o prohibir tratamientos, rectificar o suprimir, retirar certificación e imponer multas.
- Autorización y consulta: cláusulas, normas corporativas, certificación y asesoramiento previstos.

12.2. Agencia Española de Protección de Datos

La AEPD es autoridad administrativa independiente de ámbito estatal, con personalidad jurídica y plena capacidad pública y privada. Se relaciona orgánicamente con el Gobierno a través del Ministerio de Justicia, pero actúa con independencia.

Su Presidencia dirige y representa la Agencia, dicta resoluciones, circulares y directrices y es auxiliada por una Adjuntía. Ambas son nombradas por el Gobierno a propuesta del Ministerio de Justicia tras procedimiento público de mérito, capacidad e idoneidad y ratificación parlamentaria conforme a la LOPDGDD.

Las resoluciones de Presidencia agotan la vía administrativa y son recurribles directamente ante la jurisdicción contencioso-administrativa, correspondiendo su conocimiento a la Audiencia Nacional en los términos procesales.

La Agencia puede investigar, ordenar medidas provisionales, atender reclamaciones, ejercer potestad sancionadora, publicar criterios y cooperar con autoridades europeas y autonómicas.

12.3. Autoridades autonómicas

Las autoridades autonómicas ejercen funciones respecto de tratamientos del sector público de su comunidad y entidades locales de su territorio, de quienes ejercen funciones públicas en materias autonómicas o locales y de tratamientos expresamente atribuidos por el estatuto o la ley. No controlan con carácter general a cualquier empresa privada por estar físicamente en la comunidad.

Deben cooperar con la AEPD. Sus proyectos normativos y criterios pueden someterse a coordinación para asegurar aplicación coherente.

12.4. Comité Europeo y ventanilla única

En tratamientos transfronterizos actúa como autoridad principal la del establecimiento principal o único del responsable, sin excluir competencias de autoridades interesadas en los términos del RGPD. Es el mecanismo de ventanilla única.

El Comité Europeo de Protección de Datos tiene personalidad jurídica y está integrado por la jefatura de una autoridad de cada Estado y el Supervisor Europeo de Protección de Datos; la Comisión participa sin voto. Emite directrices, promueve coherencia y adopta decisiones vinculantes para resolver determinados conflictos entre autoridades.

13. Infracciones, sanciones y responsabilidad

13.1. Multas del RGPD

Las sanciones deben ser efectivas, proporcionadas y disuasorias. Se valoran naturaleza, gravedad, duración, intencionalidad, medidas paliativas, responsabilidad, antecedentes, cooperación, categorías de datos, forma de conocimiento, cumplimiento de medidas, adhesión a códigos y agravantes o atenuantes.

Existen dos máximos:

Grupo	Máximo
Obligaciones como diseño, encargado, registros, seguridad, brechas, impacto o delegado	10 millones de euros o 2 % del volumen de negocio mundial anual, la mayor
Principios, bases, consentimiento, derechos, transferencias o incumplimiento de orden	20 millones de euros o 4 %, la mayor

La multa puede imponerse además de otras medidas. No toda infracción alcanza el máximo; debe individualizarse.

13.2. Clasificación y prescripción española

La LOPDGDD clasifica, a efectos de prescripción, infracciones muy graves, graves y leves:

- Muy graves: prescriben a los tres años.
- Graves: a los dos años.
- Leves: al año.

Las sanciones de hasta 40.000 euros prescriben al año; las de 40.001 a 300.000, a los dos; y las superiores a 300.000, a los tres.

13.3. Sector público

Cuando infringen determinadas Administraciones, organismos públicos, autoridades independientes, Banco de España, corporaciones de Derecho público en funciones públicas, fundaciones del sector público u otros sujetos del artículo 77 LOPDGDD, la autoridad dicta resolución declarando la infracción y establece medidas para cesar o corregir, mediante apercibimiento, no la multa administrativa ordinaria.

Puede proponer actuaciones disciplinarias, comunicar al defensor del pueblo y publicar la resolución. Esta especialidad no convierte al sector público en inmune: subsisten órdenes correctivas, control jurisdiccional y posibles responsabilidades disciplinarias, patrimoniales o penales.

14. Cuadros de diferencias

14.1. Supresión, limitación, oposición y portabilidad

Derecho	Efecto principal	Clave
Supresión	Eliminar cuando concurre causa	Tiene excepciones
Limitación	Congelar usos, salvo los permitidos	Se conserva el dato
Oposición	Cesar por situación particular	En marketing es absoluta
Portabilidad	Recibir/transmitir datos	Consentimiento o contrato y automatización

14.2. Plazos que se confunden

Supuesto	Plazo
Respuesta a un derecho	1 mes
Ampliación por complejidad o número	2 meses más
Información indirecta	Máximo 1 mes, salvo primera comunicación anterior
Acceso potencialmente repetitivo	Más de una vez en 6 meses
Notificación de brecha a autoridad	En lo posible, 72 horas
Conservación ordinaria de videovigilancia	Máximo 1 mes
Entrega de imágenes de incidente a autoridad	Máximo 72 horas

14.3. Roles

Sujeto	Función
Responsable	Decide fines y medios
Encargado	Trata por cuenta del responsable
Delegado	Asesora, supervisa y contacta; no sustituye al responsable
Autoridad de control	Supervisa, investiga y corrige con independencia

15. Trampas frecuentes

1. Dato personal no es solo dato íntimo. Basta que se refiera a persona identificada o identificable.
2. Seudonimizar no es anonimizar. Si puede reidentificarse con información adicional, sigue el RGPD.
3. Encargado no decide la finalidad. Si la decide, puede convertirse en responsable.
4. Consentimiento no es la única base. Hay seis bases del artículo 6.
5. La Administración no necesita pedir consentimiento para ejercer una competencia legal.
6. Retirar consentimiento no vuelve ilícito el tratamiento anterior.
7. Menor de catorce años no presta por sí solo el consentimiento ordinario español.
8. Datos penales no son una categoría especial del artículo 9. Tienen régimen propio en el artículo 10.
9. Interés legítimo no habilita a la autoridad pública en el ejercicio de sus funciones.

10. Información por capas no permite omitir información. Solo distribuye su presentación.
11. El plazo de derechos es un mes, no treinta días ni 72 horas.
12. La ampliación no es automática. Debe justificarse y avisarse dentro del primer mes.
13. Acceso no significa entregar documentos íntegros sin proteger a terceros. Se facilita información y copia de datos.
14. Supresión no es absoluta. Puede prevalecer obligación legal, libertad de información, archivo o reclamación.
15. Limitación no equivale a borrado. El dato permanece con usos restringidos.
16. Portabilidad no se aplica a cualquier soporte manual ni a toda base jurídica.
17. Oposición a marketing es más fuerte que la oposición ordinaria.
18. Solo las decisiones exclusivamente automatizadas y significativas activan el artículo 22.
19. Una brecha no siempre se comunica al interesado. Solo si es probable el alto riesgo; toda brecha se documenta.
20. 72 horas cuentan desde que el responsable tiene constancia, no necesariamente desde el instante técnico inicial.
21. El delegado no es el responsable del tratamiento.
22. Evaluación de impacto no es una autorización. La consulta previa solo procede si queda alto riesgo.
23. Bloqueo nacional no es limitación del artículo 18.
24. AEPD y Comité Europeo no son lo mismo. Una es autoridad nacional; el otro coordina la aplicación europea.
25. El sector público puede ser infractor aunque no reciba multa ordinaria.

16. Resumen final de memoria

- El artículo 18.4 CE sustenta el derecho autónomo al control de datos.
- RGPD es directamente aplicable; LOPDGDD lo adapta y completa.
- Dato personal identifica o hace identificable; tratamiento comprende casi cualquier operación.
- Responsable decide fines y medios; encargado actúa por cuenta de aquel.
- Los siete principios culminan en responsabilidad proactiva.
- Toda operación necesita base del artículo 6; el consentimiento es solo una de seis.
- El consentimiento debe ser libre, específico, informado, inequívoco y revocable.
- En España puede consentir por sí el mayor de catorce años, salvo regla especial.
- Las categorías del artículo 9 están en principio prohibidas y requieren excepción.
- La información cambia según el dato se obtenga directa o indirectamente.
- Los derechos se atienden en un mes, ampliable otros dos con aviso motivado.
- Acceso conoce y obtiene copia; rectificación corrige; supresión elimina con excepciones; limitación restringe.
- Portabilidad exige consentimiento o contrato y tratamiento automatizado.
- Oposición por situación particular admite ponderación; en marketing es absoluta.

- Las decisiones exclusivamente automatizadas significativas están limitadas y exigen garantías.
- Privacidad desde el diseño, registro, seguridad, evaluación y contratos materializan cumplimiento.
- Brecha con riesgo se notifica a autoridad en lo posible en 72 horas; con alto riesgo también al interesado.
- El delegado es obligatorio en sector público, salvo tribunales en función judicial, y en otros supuestos.
- AEPD es autoridad estatal independiente; existen autoridades autonómicas y Comité Europeo.
- Los máximos sancionadores son 10 millones/2 % y 20 millones/4 %.
- En determinados sujetos públicos se declara infracción, apercibe y corrige, sin multa ordinaria.

17. Datos preguntables

Dato	Respuesta
Fundamento constitucional	Artículo 18.4 CE
Norma europea central	Reglamento (UE) 2016/679
Aplicación del RGPD	25 de mayo de 2018
Norma española	LO 3/2018, de 5 de diciembre
Régimen penal-policial específico	LO 7/2021
Principios	Artículo 5 RGPD
Bases de licitud	Artículo 6 RGPD
Categorías especiales	Artículo 9 RGPD
Datos penales	Artículo 10 RGPD
Edad española de consentimiento	Mayor de 14 años
Información directa	Artículo 13 RGPD
Información indirecta	Artículo 14 RGPD; máximo 1 mes
Plazo de ejercicio	1 mes
Ampliación	2 meses adicionales
Acceso repetitivo según LOPDGDD	Más de una vez cada 6 meses, salvo causa
Portabilidad	Consentimiento o contrato y tratamiento automatizado
Brecha a autoridad	En lo posible, 72 horas
Brecha al interesado	Sin dilación si probable alto riesgo
Videovigilancia	Supresión máxima 1 mes
Imágenes de incidente a autoridad	Máximo 72 horas
Evaluación de impacto	Artículo 35 RGPD
Delegado	Artículos 37 a 39 RGPD
Autoridad estatal	AEPD
Autoridad europea coordinadora	Comité Europeo de Protección de Datos
Multa inferior máxima	10 millones o 2 %
Multa superior máxima	20 millones o 4 %
Prescripción infracción muy grave/grave/leve	3/2/1 años

Antecedentes de examen y puntos especialmente preguntados

El análisis se ha realizado sobre las preguntas oficiales de acceso libre publicadas para las convocatorias 2023, 2024 y 2025, con fecha de corte 30 de julio de 2026. La base conserva las variantes necesarias para la trazabilidad, pero el recuento de frecuencia usa una sola variante canónica por sesión, de modo que los modelos o colores que únicamente permutan el orden o las opciones no se cuentan dos veces. Este criterio permite medir repeticiones reales entre sesiones sin inflar artificialmente la presencia del tema.

Indicador	Resultado para G22
Preguntas canónicas atribuidas	5
Distribución por año de examen	2024: 1, 2025: 3, 2026: 1

Indicador	Resultado para G22
Teóricas / prácticas	5 / 0
Preguntas de reserva	0
Anuladas / con respuesta modificada	0 / 0
Enunciados con excepción, negación o respuesta incorrecta	1

Normas que más aparecen: Ley Orgánica 3/2018 (3); Reglamento (UE) 2016/679 (1).

Artículos o preceptos más repetidos: 13 (2); 12 (1); 12.5 (1).

Formas de pregunta predominantes: Artículos literales (5).

Patrones observados

- 2024, teoría 22: La Ley Orgánica 312018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales establece en el artículo 13 y siguientes que serán derechos de las personas o afectados:
- 2025, teoría 22: De acuerdo con lo dispuesto en el art. 44 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantías de los derechos digitales, señale la afirmación correcta en relación con...
- 2025, teoría 22: Según las disposiciones generales sobre el ejercicio de los derechos recogidas en el artículo 12 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos...
- 2025, teoría 22: La Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, establece en su artículo 13 que, a los efectos establecidos en el artículo 12.5 del...
- 2026, teoría 27: Según el art. 6 del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016, el tratamiento de los datos solo es lícito si se cumple al menos una de las siguientes condiciones:...

Cómo trasladarlo al estudio

1. Priorice la literalidad útil. Memorice la regla, su artículo y la excepción, pero comprenda antes quién actúa, sobre qué supuesto y con qué plazo.
2. Entrene las negaciones. En este tema se han localizado 1 enunciados con fórmulas como «INCORRECTA», «NO», «salvo» o «excepto». Subraye siempre el mandato antes de leer las opciones.
3. Separe regla estable y dato anual. Cuando intervengan cuantías, bases, tipos, edades o porcentajes, anote el año de referencia y contraste la cifra con la norma consolidada vigente.
4. Use las anulaciones como señal de riesgo. Una pregunta anulada no desaparece del aprendizaje: suele revelar una redacción ambigua, una reforma reciente o dos preceptos que deben diferenciarse.
5. No confunda frecuencia con seguridad de aparición. El recuento describe el corpus disponible; no garantiza la distribución de una convocatoria futura ni permite excluir epígrafes poco preguntados.

Fuentes oficiales utilizadas

- Constitución Española, texto consolidado
(<https://www.boe.es/buscar/act.php?id=BOE-A-1978-31229>).

- Reglamento (UE) 2016/679, texto oficial en EUR-Lex (<https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:02016R0679-20160504>).
- Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, texto consolidado (<https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673>).
- Ley Orgánica 7/2021, de 26 de mayo, de protección de datos tratados para fines penales, texto consolidado (<https://www.boe.es/buscar/act.php?id=BOE-A-2021-8806>).
- Agencia Española de Protección de Datos, portal oficial (<https://www.aepd.es/>).
- Comité Europeo de Protección de Datos, portal oficial (https://www.edpb.europa.eu/edpb_es).